

Website Vulnerability Scanner Report

✓ <https://brins.co.id/>

Target added due to a redirect from <https://brins.co.id/>

Summary

Overall risk level:

Medium

Risk ratings:

Critical: 0

High: 0

Medium: 4

Low: 2

Info: 67

Scan information:

Start time: Feb 02, 2026 / 23:51:08 UTC+07

Finish time: Feb 03, 2026 / 02:40:37 UTC+07

Scan duration: 2 hrs, 49 min, 29 sec

Tests performed: 73/73

Scan status: **Finished**

Findings

Insecure cookie setting: missing HttpOnly flag

CONFIRMED

port 443/tcp

URL	Cookie Name	Evidence
https://brins.co.id/	domain, TSa5bb68c2027, TS01d9e5a3	The server responded with Set-Cookie header(s) that does not specify the HttpOnly flag: Set-Cookie: domain=.brins.co.id Set-Cookie: TSa5bb68c2027=08da83dfadab200091457006a04e9c795318d3ce2c3cbad1b7797ac7571cde341f1d9e25cce6dca308f1eb3131113000004efdfc291c7bcc1d974952462c20fd6a74e2cb09dc9c04ed485e6e22ab8ef3fd97bf4faa49319f7390dc6f7bb32f48 Set-Cookie: TS01d9e5a3=01e6a1e6a799239ae0395b4649f703bbde1d1c9f49829f5dff885092dac2c300c21382b6f781829e5befeb54e5c45442332564947b77d140155c00d0589293f45d7af734311e342ab9569abdf7e0c5d632190518d9 Request / Response

Details

Risk description:

The risk is that an attacker who injects malicious JavaScript code on the page (e.g. by using an XSS attack) can access the cookie and can send it to another site. In case of a session cookie, this could lead to session hijacking.

Recommendation:

Ensure that the HttpOnly flag is set for all cookies.

References:

<https://owasp.org/www-community/HttpOnly>

Classification:

CWE : [CWE-1004](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

Insecure cookie setting: missing Secure flag

CONFIRMED

port 443/tcp

URL	Cookie Name	Evidence
-----	-------------	----------

https://brins.co.id/	domain, TSa5bb68c2027, TS01d9e5a3	Set-Cookie: domain=.brins.co.id Set-Cookie: TSa5bb68c2027=08da83dfadab200091457006a04e9c795318d3ce2c3cbad1b7797ac7571cde341f1d9e25cce6dca308f1eb3131113000004efdfc291c7bcc1d974952462c20fd6a74e2cb09dc9c04ed485e6e22ab8ef3fd97bf4faa49319f7390dc6f7bb32f48 Set-Cookie: TS01d9e5a3=01e6a1e6a799239ae0395b4649f703bbde1d1c9f49829f5dff885092dac2c300c21382b6f781829e5befeb54e5c45442332564947b77d140155c00d0589293f45d7af734311e342ab9569abdf7e0c5d632190518d9 Request / Response
---	---	--

▼ Details

Risk description:

The risk exists that an attacker will intercept the clear-text communication between the browser and the server and he will steal the cookie of the user. If this is a session cookie, the attacker could gain unauthorized access to the victim's web session.

Recommendation:

Whenever a cookie contains sensitive information or is a session token, then it should always be passed using an encrypted channel. Ensure that the secure flag is set for cookies containing such sensitive information.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html

Classification:

CWE : [CWE-614](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)



Insecure cookie setting: domain too loose

CONFIRMED

port 443/tcp

URL	Cookie Name	Evidence
https://brins.co.id/	TS01d9e5a3	Set-Cookie: .brins.co.id Request / Response

▼ Details

Risk description:

The risk is that a cookie set for example.com may be sent along with the requests sent to dev.example.com, calendar.example.com, hostedsite.example.com. Potentially risky websites under your main domain may access those cookies and use the victim session from the main site.

Recommendation:

The **Domain** attribute should be set to the origin host to limit the scope to that particular server. For example if the application resides on server app.mysite.com, then it should be set to **Domain=app.mysite.com**

Classification:

CWE : [CWE-614](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)



Vulnerabilities found for ckeditor 4.18.0

port 443/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
CVE-2023-28439	4.7	0.00394	0.59929	cross-site scripting vulnerability has been discovered affecting Iframe Dialog and Media Embed packages. The vulnerability may trigger a JavaScript code. More details at: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-28439 https://github.com/ckeditor/ckeditor4/security/advisories/GHSA-vh5c-xwqv-cv9g Affected file: https://cdn.ckeditor.com/4.18.0/full-all/ckeditor.js

▼ Details

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.00394
EPSS percentile : 0.59929
CISA KEV: False
CVE : [CVE-2023-28439](#)
CVSS V3 : 4.7
CWE : [CWE-1035](#)

 Unsafe security header: Content-Security-Policy

port 443/tcp

CONFIRMED

URL	Evidence
https://brins.co.id/	Response headers include the HTTP Content-Security-Policy security header with the following security issues: <pre>script-src: 'self' can be problematic if you host JSONP, Angular or user uploaded files. object-src: We recommend restricting object-src to 'none'. script-src: 'unsafe-eval' allows the execution of code injected into DOM APIs such as eval(). script-src: 'unsafe-inline' allows the execution of unsafe in-page scripts and event handlers. script-src: data: URI in script-src allows the execution of unsafe scripts. script-src: https: URI in script-src allows the execution of unsafe scripts. frame-ancestors: This directive tells the browser whether you want to allow your site to be framed or not. By preventing a browser from framing your site you can defend against attacks like clickjacking. The recommended value is 'none' or 'self'.</pre> Request / Response

 Details**Risk description:**

For example, if the unsafe-inline directive is present in the CSP header, the execution of inline scripts and event handlers is allowed. This can be exploited by an attacker to execute arbitrary JavaScript code in the context of the vulnerable application.

Recommendation:

Remove the unsafe values from the directives, adopt nonces or hashes for safer inclusion of inline scripts if they are needed, and explicitly define the sources from which scripts, styles, images or other resources can be loaded.

References:

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy>

Classification:

CWE : [CWE-693](#)
OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)
OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

 Server software and technology found

port 443/tcp

UNCONFIRMED 

Software / Version	Category
 Angular 15.2.9	JavaScript frameworks
 CKEditor	Rich text editors
 dc.js	JavaScript graphics, JavaScript libraries
 Zone.js	JavaScript frameworks
 asm	Miscellaneous

 Google Analytics GA4	Analytics
 Google Font API	Font scripts
 lit-element 4.1.1	JavaScript libraries
 Google Maps	Maps
 Open Graph	Miscellaneous
 Sectigo	SSL/TLS certificate authorities
 PWA	Miscellaneous
 Google Tag Manager	Tag managers
 HSTS	Security
 TypeScript	Programming languages

▼ Details

Risk description:

The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:

We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server.html

Classification:

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

Screenshot:

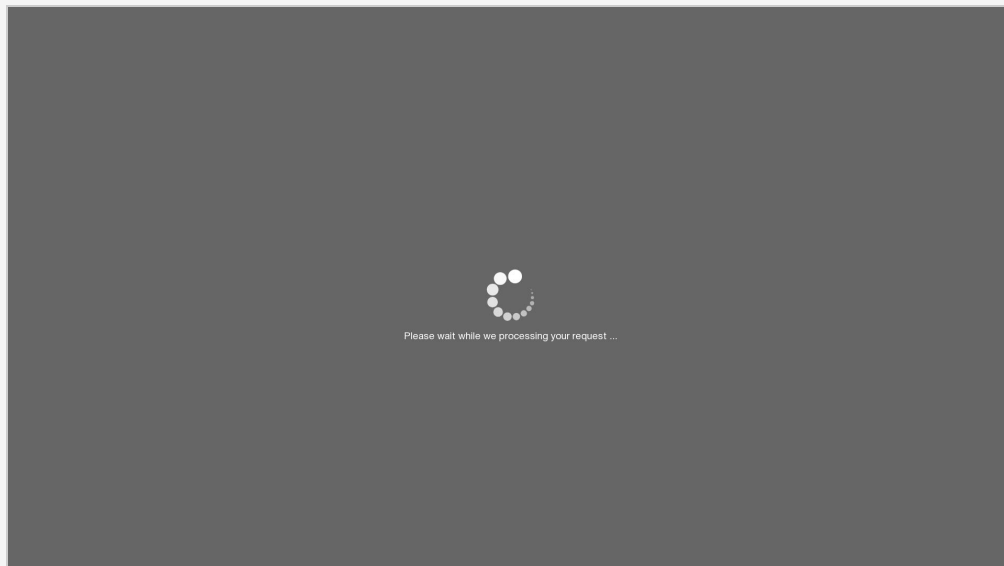


Figure 1. Website Screenshot

Email Address Exposure

port 443/tcp

UNCONFIRMED ⓘ

URL	Method	Parameters	Evidence
-----	--------	------------	----------

https://brins.co.id/	GET	Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Email Address: digital@work.brins.co.id Request / Response
---	-----	---	--

▼ Details

Risk description:

The risk is that exposed email addresses within the application could be accessed by unauthorized parties. This could lead to privacy violations, spam, phishing attacks, or other forms of misuse.

Recommendation:

Compartmentalize the application to have 'safe' areas where trust boundaries can be unambiguously drawn. Do not allow email addresses to go outside of the trust boundary, and always be careful when interfacing with a compartment outside of the safe area.

References:

https://owasp.org/Top10/A04_2021-Insecure_Design/

Classification:

CISA KEV: False

CVE : -1

CWE : [CWE-200](#)

OWASP Top 10 - 2017 : A6: Security Misconfiguration

OWASP Top 10 - 2021 : A4: Insecure Design

Spider Results

UNCONFIRMED ⓘ

URL	Method	Page Title	Page Size	Status Code
https://brins.co.id/helveticaeuecyr_roman.05e5043d234d97f0.eot	GET	BRINS BRI INSURANCE	69.12 KB	200
https://brins.co.id/helveticaeuecyr_roman.4d43e0d49a162d0f.ttf	GET	BRINS BRI INSURANCE	60.26 KB	200
https://brins.co.id/helveticaeuecyr_roman.e709237239dab033.woff	GET	BRINS BRI INSURANCE	69.12 KB	200
https://brins.co.id/	GET	BRINS BRI INSURANCE	34.52 KB	200
https://brins.co.id/assets/icons/sakina	GET	403 Forbidden	534 B	200
https://brins.co.id/home	GET	BRINS BRI INSURANCE	56.01 KB	200
https://brins.co.id/home/about	GET	BRINS BRI INSURANCE	60.26 KB	200

▼ Details

Risk description:

The table contains all the unique pages the scanner found. The duplicated URLs are not available here as scanning those is considered unnecessary.

Recommendation:

We recommend to advanced users to make sure the scan properly detected most of the URLs in the application.

References:

[All the URLs the scanner found, including duplicates](#) (available for 90 days after the scan date)

Interesting files found

port 443/tcp

UNCONFIRMED ⓘ

URL	Page Title	Page Size	Summary
https://login.microsoftonline.com:443/brins.co.id/v2.0/.well-known/openid-configuration		3.49 KB	Microsoft Azure Domain Tenant ID was detected.
https://brins.co.id/hopfully404	BRINS BRI INSURANCE	43.26 KB	

https://brins.co.id	BRINS BRI INSURANCE	43.26 KB	
---	--------------------------	-------------	--

▼ Details

Risk description:

The risk is that these files/folders usually contain sensitive information which may help attackers to mount further attacks against the server. Manual validation is required.

Recommendation:

We recommend you to analyze if the mentioned files/folders contain any sensitive information and restrict their access according to the business purposes of the application.

Classification:

CWE : [CWE-200](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

🚩 Misconfigurations

port 443/tcp

UNCONFIRMED ⓘ

URL	Page Title	Page Size	Summary
https://brins.co.id/	BRINS BRI INSURANCE	43.26 KB	Checks if external script and stylesheet tags in the HTML response are missing the Subresource Integrity (SRI) attribute.

▼ Details

Risk description:

Depending on the misconfiguration present, the risk varies from information disclosure to possible execution of arbitrary code. A malicious actor can gain knowledge into the application's inner functionalities and services, obtain unauthorized access or make use of various security issues like execution of arbitrary code.

Recommendation:

We recommend you to analyze the configurations discovered, make sure the right options are set it, limit access to these resources and verify the application is not exposing information through these configurations.

Classification:

CWE : [CWE-200](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

🚩 Nothing was found for client access policies.

🚩 Nothing was found for robots.txt file.

🚩 Nothing was found for absence of the security.txt file.

🚩 Nothing was found for CORS misconfiguration.

🚩 Nothing was found for use of untrusted certificates.

🚩 Nothing was found for enabled HTTP debug methods.

🚩 Nothing was found for administration consoles.

🚩 Nothing was found for information disclosure.

🚩 Nothing was found for software identification.

🚩 Nothing was found for sensitive files.

🚩 Searching for URLs in Wayback Machine.

🚩 Nothing was found for enabled HTTP OPTIONS method.

🚩 Nothing was found for GraphQL endpoints.

🚩 Fuzzed for OpenAPI files.

🚩 Nothing was found for secure communication.

🚩 Nothing was found for directory listing.

🚩 Nothing was found for passwords submitted unencrypted.

🚩 Nothing was found for Cross-Site Scripting.

🚩 Nothing was found for SQL Injection.

🚩 Nothing was found for Local File Inclusion.

🚩 Nothing was found for OS Command Injection.

🚩 Nothing was found for error messages.

🚩 Nothing was found for debug messages.

🚩 Nothing was found for code comments.

🚩 Nothing was found for missing HTTP header - Strict-Transport-Security.

🚩 Nothing was found for missing HTTP header - Content Security Policy.

🚩 Nothing was found for missing HTTP header - X-Content-Type-Options.

🚩 Nothing was found for missing HTTP header - Referrer.

🚩 Nothing was found for XML External Entity Injection.

🚩 Nothing was found for Insecure Direct Object Reference.

🚩 Nothing was found for passwords submitted in URLs.

🚩 Nothing was found for mixed content between HTTP and HTTPS.

🚩 Nothing was found for cross domain file inclusion.

🚩 Nothing was found for internal error code.

🚩 Nothing was found for login interfaces.

🚩 Nothing was found for secure password submission.

🚩 Nothing was found for sensitive data.

🚩 Nothing was found for Server Side Request Forgery.

🚩 Nothing was found for Open Redirect.

🚩 Nothing was found for PHP Code Injection.

🚩 Nothing was found for JavaScript Code Injection.

🚩 Nothing was found for Ruby Code Injection.

🚩 Nothing was found for Python Code Injection.

🚩 Nothing was found for Perl Code Injection.

🚩 Nothing was found for Remote Code Execution through Log4j.

🚩 Nothing was found for Server Side Template Injection.

🚩 Nothing was found for Remote Code Execution through VIEWSTATE.

🚩 Nothing was found for Prototype Pollution.

🚩 Nothing was found for Exposed Backup Files.

🚩 Nothing was found for Request URL Override.

🚩 Nothing was found for HTTP/1.1 Request Smuggling.

🚩 Nothing was found for CSRF

🚩 Nothing was found for NoSQL Injection.

🚩 Nothing was found for Insecure Deserialization.

🚩 Nothing was found for OpenAPI files.

🚩 Nothing was found for file upload.

🚩 Nothing was found for SQL statement in request parameter.

🚩 Nothing was found for password returned in later response.

🚩 Nothing was found for Path Disclosure.

🚩 Nothing was found for Session Token in URL.

🚩 Nothing was found for API endpoints.

🚩 Nothing was found for Response Header Injection.

🚩 Nothing was found for missing HTTP header - Rate Limit.

List of tests performed (73/73)

- ✓ Scanned for HttpOnly flag of cookie
- ✓ Scanned for Secure flag of cookie

- ✓ Scanned for emails
- ✓ Scanned for domain too loose set for cookies
- ✓ Scanned for unsafe HTTP header Content Security Policy
- ✓ Spider target
- ✓ Scanned for website technologies
- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for client access policies
- ✓ Scanned for robots.txt file
- ✓ Scanned for absence of the security.txt file
- ✓ Scanned for CORS misconfiguration
- ✓ Scanned for use of untrusted certificates
- ✓ Scanned for enabled HTTP debug methods
- ✓ Scanned for administration consoles
- ✓ Scanned for information disclosure
- ✓ Scanned for software identification
- ✓ Scanned for sensitive files
- ✓ Scanned for interesting files
- ✓ Performed URL search in Wayback Machine
- ✓ Scanned for enabled HTTP OPTIONS method
- ✓ Scanned for GraphQL endpoints
- ✓ Performed fuzzing for OpenAPI files
- ✓ Scanned for misconfigurations
- ✓ Scanned for secure communication
- ✓ Scanned for directory listing
- ✓ Scanned for passwords submitted unencrypted
- ✓ Scanned for Cross-Site Scripting
- ✓ Scanned for SQL Injection
- ✓ Scanned for Local File Inclusion
- ✓ Scanned for OS Command Injection
- ✓ Scanned for error messages
- ✓ Scanned for debug messages
- ✓ Scanned for code comments
- ✓ Scanned for missing HTTP header - Strict-Transport-Security
- ✓ Scanned for missing HTTP header - Content Security Policy
- ✓ Scanned for missing HTTP header - X-Content-Type-Options
- ✓ Scanned for missing HTTP header - Referrer
- ✓ Scanned for XML External Entity Injection
- ✓ Scanned for Insecure Direct Object Reference
- ✓ Scanned for passwords submitted in URLs
- ✓ Scanned for mixed content between HTTP and HTTPS
- ✓ Scanned for cross domain file inclusion
- ✓ Scanned for internal error code
- ✓ Scanned for login interfaces
- ✓ Scanned for secure password submission
- ✓ Scanned for sensitive data
- ✓ Scanned for Server Side Request Forgery
- ✓ Scanned for Open Redirect
- ✓ Scanned for PHP Code Injection
- ✓ Scanned for JavaScript Code Injection
- ✓ Scanned for Ruby Code Injection
- ✓ Scanned for Python Code Injection
- ✓ Scanned for Perl Code Injection
- ✓ Scanned for Remote Code Execution through Log4j
- ✓ Scanned for Server Side Template Injection
- ✓ Scanned for Remote Code Execution through VIEWSTATE
- ✓ Scanned for Prototype Pollution
- ✓ Scanned for Exposed Backup Files
- ✓ Scanned for Request URL Override
- ✓ Scanned for HTTP/1.1 Request Smuggling
- ✓ Scanned for CSRF
- ✓ Scanned for NoSQL Injection
- ✓ Scanned for Insecure Deserialization
- ✓ Scanned for OpenAPI files
- ✓ Scanned for file upload
- ✓ Scanned for SQL statement in request parameter
- ✓ Scanned for password returned in later response
- ✓ Scanned for Path Disclosure
- ✓ Scanned for Session Token in URL
- ✓ Scanned for API endpoints
- ✓ Scanned for Response Header Injection
- ✓ Scanned for missing HTTP header - Rate Limit

Scan parameters

Target: <https://brins.co.id/>
 Scan type: Deep_scan_default
 Authentication: False
 fingerprint: True

software_vulnerabilities:	True
check_robots:	True
outdated_js:	True
untrusted_certificates:	True
client_access_policies:	True
http_debug_methods:	True
security_txt:	True
cors_misconfiguration:	True
resource_discovery:	True
sensitive_files:	True
admin_consoles:	True
interesting_files:	True
server_info_disc:	True
server_software:	True
misconfigurations:	True
graphql_endpoint:	True
fuzz_openapi_locations:	True
approach:	Auto
depth:	10
requests_per_second:	100
xss:	True
sqli:	True
lfi:	True
oscmdi:	True
ssrf:	True
open_redirect:	True
broken_authentication:	True
php_code_injection:	True
js_code_injection:	True
ruby_code_injection:	True
python_code_injection:	True
perl_code_injection:	True
log4j_rce:	True
ssti:	True
xxe:	True
viewstate_rce:	True
prototype_pollution:	True
backup_files:	True
request_url_override:	True
http_request_smuggling:	True
csrf:	True
insecure_deserialization:	True
nosqli:	True
session_fixation:	True
idor:	True
jwt:	True
response_header_injection:	True
security_headers:	True
cookie_security:	True
directory_listing:	True
secure_communication:	True
weak_password_submission:	True
error_debug_messages:	True
password_cleartext:	True
cross_domain_source:	True
mixed_content:	True
sensitive_data:	True
login_interfaces:	True
file_upload:	True
openapi_documents:	True
path_disclosure:	True
sql_statement_in_request:	True
password_in_response:	True
session_token_in_url:	True
api_endpoint:	True

Scan stats

Unique Injection Points Detected:	32
URLs spidered:	58
Total number of HTTP requests:	25734
Average time until a response was received:	326ms
Total number of HTTP request errors:	101

